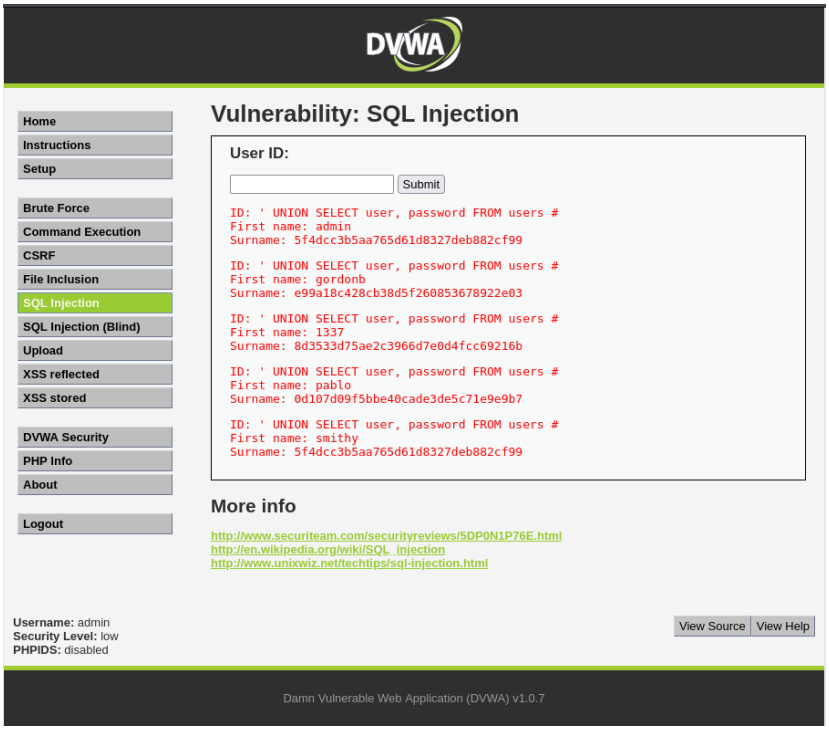
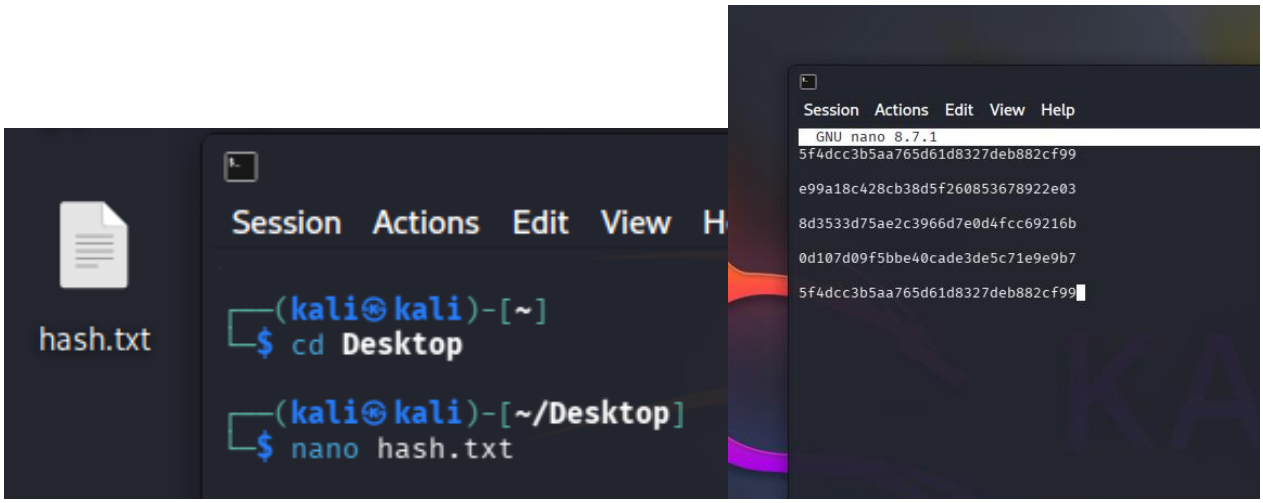
S6-L4

Obiettivo dell'Esercizio: Recuperare le password hashate nel database della DVWA e eseguire sessioni di cracking per recuperare la loro versione in chiaro utilizzando i tool studiati nella lezione teorica.



Preparazione del file target: Gli hash estratti sono stati salvati in un file di testo denominato hash.txt all'interno della macchina Kali Linux. È stato osservato che il primo e l'ultimo hash del set erano identici, suggerendo l'uso della stessa password per account diversi.



Configurazione dell'attacco: Per l'operazione di cracking è stato utilizzato lo strumento **John the Ripper (JtR)**. Si è scelto di eseguire un attacco a dizionario puntando alla wordlist standard rockyou.txt.

Esecuzione del comando: Il comando lanciato nel terminale è stato:
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

```
┌──(kali㉿kali)-[/usr/share/wordlists]
└─$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt ~/Desktop/hash.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
password         (?)
abc123           (?)
letmein          (?)
charley          (?)
4g 0:00:00:00 DONE (2026-04-09 07:14) 400.0g/s 307200p/s 307200c/s 460800C/s my3kids..dangerous
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

┌──(kali㉿kali)-[/usr/share/wordlists]
└─$ john --show --format=raw-md5 /home/kali/Desktop/hash.txt
?:password
?:abc123
?:charley
?:letmein
?:password

5 password hashes cracked, 0 left
```

Risultati ottenuti Il software ha completato il confronto con successo, identificando le seguenti corrispondenze:

- **5f4dcc3b5aa765d61d8327deb882cf99** = password
- **e99a18c428cb38d5f260853678922e03** = abc123
- **8d3533d75ae2c3966d7e0d4fcc69216b** = charley
- **0d107d09f5bbe40cade3de5c71e9e9b7** = letmein

Conclusioni Tutti i 5 hash sono stati craccati correttamente. La rapidità del processo evidenzia l'estrema insicurezza dell'algoritmo MD5 e l'importanza di utilizzare password complesse non presenti nei dizionari comuni come quello utilizzato.